

GARIL AI

Data Protection & Privacy Overview

UK GDPR / GDPR-oriented summary for university partners

Version	1.0
Date	3 October 2026
Audience	Partner universities & institutional stakeholders
Classification	Confidential — authorised institutional use

Important notice

This is an operational privacy summary to support institutional DPIAs and procurement. It is not formal legal advice. Partner universities remain controllers for student/staff personal data they introduce into the platform unless a signed DPA states otherwise.

1. Roles

In a typical university deployment, the university is the data controller for personal data of its staff and students. GARIL AI (operator/host) acts as a data processor (or joint controller only where explicitly contracted). A Data Processing Agreement (DPA) should be executed before live personal data is processed.

2. Categories of data processed

Category	Examples	Purpose
Identity & account	Name, email, role, institution, faculty/programme	Authentication, access control, tenancy
Academic activity	Research projects, papers, notes, supervision workflow	Provide research/learning features
AI interaction	Prompts, model outputs, token usage	AI assistance; governance & quotas
Admin/governance	Audit logs, incidents, policies, retention requests	Accountability & compliance
Technical	Session tokens, IP (via proxy logs), file metadata	Security & operations

3. Lawful bases (typical)

- Public task / legitimate interests — delivering university research & learning services
- Contract — where users register under institutional terms
- Consent — where policy acceptance or optional processing requires it

Universities should confirm lawful basis mapping in their DPIA. GARIL AI supports policy acceptance versioning in-product.

4. Security of processing (Art. 32 alignment)

- Access control with default-deny APIs and university scoping
- Passwords hashed (bcrypt); reset tokens hashed; short-lived sessions (24h access JWT)
- TLS in transit (institutional reverse proxy); security headers; CORS allowlist
- Rate limiting on authentication and AI endpoints
- HTML/markdown sanitisation to reduce XSS risk
- Super-admin-only full-database backups
- Defensive security audit completed with Critical findings remediated (Oct 2026)

5. International transfers

Depending on hosting and AI provider regions, personal data or prompt content may be processed outside the UK/EEA. Universities should review subprocessors (see Subprocessors PDF) and apply SCCs / UK IDTA as required in the DPA.

6. Retention & rights

- In-product retention policies and deletion-request workflows for governance teams
- Users/admins can manage research assets they own; institutional admins act within university scope
- Subject access / erasure requests should be routed via the university DPO to the operator under the DPA

7. DPIA support

This pack (Security Assurance, SOC 2 Readiness, Subprocessors, Incident Response) is intended as input to a university Data Protection Impact Assessment for AI-assisted research tools. Contact the partnership team for a completed questionnaire workbook if required.